

safe-npx technical scope

body

safe-npx is a Rust execution gate for `npx` / `npm exec`. It keeps the package execution workflow, but replaces the thin yes/no prompt with exact package evidence before remote code runs.

v0.1 must do

- Parse `safe-npx <package-spec> [-- args]`
- Resolve the root package to an exact version
- Download the root tarball without executing scripts
- Verify integrity from registry or lock metadata
- Inspect `package.json`, `bins`, lifecycle scripts, file count, size, and readability signals
- Generate a dependency graph with lifecycle scripts disabled
- Print an evidence report and ask before delegation
- Emit deterministic JSON for agents and CI

v0.1 should not do

- Replace NPM, PNPM, Yarn, or Bun
- Claim that a package is safe
- Run package lifecycle scripts during inspection
- Depend on a hosted service
- Upload private package metadata by default
- Rely on opaque AI-only scoring
- Attempt perfect JavaScript static analysis

Evidence shown before execution

Artifact

- registry
- package
- version
- tarball URL
- integrity

Provenance

- publisher
- release age
- maintainers
- repository
- audit status

Risk signals

- lifecycle scripts
- executable bins
- typo-squat similarity
- bundled or obfuscated code
- dependency warnings

Rust architecture

CLI crates

- `clap` for arguments
- `serde` / `serde_json` for reports
- `request` + `tokio` for registry fetch
- `tar`, `flate2`, `sha2`, `base64` for artifacts
- `petgraph` for dependency graph modeling

Core modules

- package spec parser
- registry client
- tarball verifier
- lockfile parser
- static signal extractor
- policy evaluator
- execution delegator

Primary demo flow

```
$ safe-npx create-example@latest
Package: create-example@2.4.1
Integrity: sha512-...
Published: 3 hours ago
Dependencies: 87 resolved nodes
Lifecycle scripts: postinstall
Recommendation: elevated risk
Continue? [y/N]
```

Public benefit commitments: MIT license, reproducible package test corpus, package-manager documentation, agent-vendor JSON schema guidance, and opt-in registry design for exact artifact audit records.